

Cybersecurity and Data Protection Standards

Document ID: MR-SEC-009 | Owner: Information Security | Status: Approved 2024

Data classification

Data is classified as Public, Internal, Confidential, or Restricted. Customer personal data and order history are Confidential.

Data residency

Confidential and Restricted data must remain in-region at rest and in transit. Cross-region replication of Confidential data requires an approved data transfer assessment.

Secrets management

Credentials, API keys, and certificates must never be stored in source code or configuration files under version control. All secrets must be held in the enterprise vault service and rotated at least every 90 days.

Encryption

Data in transit must use TLS 1.2 or higher. Data at rest must use AES-256 or platform-managed equivalent. Database connections must be encrypted.

Access control

Production access follows least privilege with quarterly access reviews. Service accounts must be non-interactive and individually owned.

Logging and monitoring

Security-relevant events must be forwarded to the enterprise SIEM within five minutes. Log retention is 13 months.